Evidence-Based Design of a Phishing Simulation Education and Training Program for XY Organisation

Anthony Mackenzi Fernando
Student Number: S4129857

***Abstract*—This report examines how XY Organisation should design a phishing simulation education and training programme. XY is a unionised energy organisation with a hybrid workforce of technical and non-technical staff. Four design issues are investigated: simulation frequency and timing, post-simulation feedback and learning, personalised versus standardised training, and the handling of individual results, privacy and trust. Evidence from eleven peer-reviewed studies indicates that repeated simulations are associated with lower click rates, although causal claims remain limited. Just-in-time feedback can improve subsequent behaviour, while conventional embedded training often shows low engagement. Proficiency-based personalisation improves classification performance in online studies but lacks workplace validation. No study directly compares aggregate-only reporting with individual disclosure. Drawing on this evidence and XY's context, the report recommends approximately quarterly simulations of moderate difficulty, brief non-punitive just-in-time feedback, light proficiency-based differentiation of training content where practical, and aggregate-only reporting of results with transparent data-use rules developed in consultation with unions. Confidence in these recommendations is moderate because of differences between the research settings and XY's workforce.**

I. Part 1: Critical Literature Review

A. Part 1.1: Design Issues

1) Issue 1: Simulation Frequency and Timing: **Decision question:** How frequently should phishing simulations be conducted at XY, and should campaign difficulty be varied?

This issue is important for XY because the organisation has a hybrid workforce of technical and non-technical staff. Simulations that are too frequent risk reduced engagement and training fatigue. Simulations that are too infrequent may fail to sustain awareness. Evidence on the relationship between campaign frequency and behavioural outcomes is therefore needed to inform a workable schedule.

2) Issue 2: Post-Simulation Feedback and Learning: **Decision question:** What form and timing of feedback or learning intervention should follow a simulated phishing event?

XY staff have limited discretionary time for training. Feedback that is delayed, lengthy or perceived as punitive may be ignored or may damage trust in a unionised setting. Clarifying the relative effectiveness of immediate brief feedback versus more formal remedial training is therefore a central design question.

3) Issue 3: Personalised Versus Standardised Training: **Decision question:** Should training content be matched to individual or group proficiency, or should a single standardised curriculum be used?

XY employs both technical and non-technical staff who are likely to differ in prior knowledge and experience with phishing. A uniform curriculum may under-challenge some groups and over-challenge others. Evidence on the benefits and limitations of proficiency-based personalisation is therefore relevant, even though practical constraints on assessment and delivery must also be considered.

4) Issue 4: Individual Results, Privacy and Trust: **Decision question:** Should individual simulation results be disclosed to managers, retained only in aggregate form, or used as the basis for formal accountability measures?

In a unionised energy organisation, disclosure of individual click data risks being perceived as surveillance. Aggregate reporting protects privacy but limits targeted support. Management may also wish to consider formal accountability for repeated failures. The trade-off between diagnostic value, trust and accountability requires careful examination.

B. Part 1.2: Literature Selection

The literature was selected to cover four design issues relevant to the development of a phishing simulation education and training programme: simulation frequency, post-simulation feedback, personalisation, and the handling of individual results. The selected studies include experimental, observational, qualitative, longitudinal and organisational studies. This allows the evidence to be considered in terms of both behavioural outcomes and employee perceptions.

C. Part 1.3: Cross-Study Evidence Synthesis

1) Issue 1: Simulation Frequency and Timing: Gordon et al. provide the clearest evidence on repeated phishing simulations. Their study of six US healthcare institutions found that higher campaign numbers were associated with lower odds of clicking subsequent simulated phishing emails. The retrospective design cannot show that repeated exposure caused the improvement. Campaign difficulty and other changes could also influence click rates [1]. A second Gordon et al. study used repeated campaigns and found declining click rates across

TABLE I
EVIDENCE MAP FOR THE FOUR DESIGN ISSUES

Study	Method / Context	Issue(s)	Main finding and relevance
Gordon et al. [1]	Retrospective analysis of 95 simulated campaigns (nearly 3 million emails) across six US healthcare institutions.	Frequency and timing	Higher numbers of prior campaigns associated with lower odds of clicking subsequent emails. Suggests a possible benefit of repetition, but the design is observational and campaign difficulty was not controlled.
Gordon et al. [2]	Repeated campaigns at one US healthcare system. Mandatory training was imposed on employees who clicked at least five emails.	Frequency, feedback/training	Click rates decreased for both the higher-risk ("offender") group and the lower-risk group across 20 campaigns. Mandatory training after campaign 15 produced no substantial additional reduction. The study cannot isolate the effect of the training because there was no control group of repeat clickers who did not receive it.
Ho et al. [3]	Eight-month randomised controlled experiment with ten simulated campaigns involving more than 19 500 employees at a large US healthcare organisation.	Feedback, training engagement	Absolute differences in failure rates between employees who received embedded training and those who did not were extremely small. Most users spent minimal time with the training material. Conventional embedded training appears to offer limited practical value under the conditions studied.
Bender et al. [4]	Field experiment with approximately 11 000 employees of a large U.S. health solutions organization. Just-in-time feedback was randomised after the first simulated phishing email.	Feedback and learning	Just-in-time feedback reduced susceptibility to a second simulated email two weeks later. Among those who ignored the first email, feedback also increased later reporting. Supports brief feedback delivered at the moment of the event.
Chen et al. [5]	Seven focus groups ($N = 34$) with employees at a European university, analysed using Expectancy-Value Theory.	Privacy, trust, motivation	Privacy concerns, fear of consequences and lack of feedback or communication discouraged engagement and reporting. Perceived value of the intervention and organisational culture influenced participation.
Schöni et al. [6]	Online experiment ($N = 342$) comparing personalised training (based on a composite proficiency score) with randomly assigned training.	Personalisation	Participants showed overall gains in proficiency, detection ability and security attitude after training. Effects were most pronounced in the personalised condition, which also reduced disparities between initial proficiency groups. Many direct comparisons lacked statistical significance. An exploratory analysis indicated that the match between training and proficiency was an important factor. Evidence is limited to online classification tasks.
Schöni et al. [7]	Two online studies ($N = 96$ and $N = 158$) assigning participants to proficiency-based training groups.	Personalisation	Proficiency-based categorisation improved overall proficiency and reduced disparities across groups. Effects transferred to classification accuracy. The studies do not fully establish superiority over a well-designed standardised programme in a workplace setting.
Beu et al. [8]	Naturalistic organisational phishing simulation followed by a survey of targeted employees.	Personalisation, individual results	Lower phishing detection accuracy only modestly predicted riskier behaviour. Fewer years of employment and lower employee satisfaction and loyalty were more strongly associated with unsafe behaviour. Individual click results are incomplete indicators of security behaviour.
Reeves et al. [9]	Qualitative interviews ($N = 24$) and development of a cybersecurity advice-fatigue scale ($N = 457$).	Frequency, training fatigue	Employees infer organisational motives behind training content. Generic or poorly designed material can produce advice fatigue and reduce receptivity. Relevant to the quality and perceived legitimacy of any simulation programme.
Grill et al. [10]	Longitudinal randomised controlled trial of combined employee training and managerial behavioural training over 16 months.	Results, organisational security culture	Significant positive effects on managers' information-security leadership. Employee-level effects were largely limited to information-security learning. Supports attention to culture and leadership but does not address disclosure of individual phishing results.
Rizzoni et al. [11]	Case study of three phishing-simulation campaigns in a large Italian hospital (more than 6 000 staff).	Individual results, privacy, trust	The campaigns generated internal organisational concerns. Staff approached labour unions, and the unions requested that further emails be blocked. The authors reported that successful ethical simulations require coordination across the organisation, including human resources and unions, and that misleading messages can produce backlash from staff and unions.

campaigns for both higher- and lower-risk groups. Campaign-specific difficulty varied, and mandatory training for repeat clickers did not produce substantial additional improvement [2]. The two studies therefore point in the same direction, but neither establishes an optimal frequency. Ho et al. examined training engagement rather than simulation frequency. Reeves et al. studied security education and training more generally rather than the frequency of phishing simulations [3], [9]. Therefore, these studies should not be treated as direct evidence for a particular simulation schedule.

For XY, the strongest frequency evidence comes from US healthcare organisations rather than an energy workforce. In addition, declining click rates in simulated campaigns do not necessarily demonstrate improved protection against real phishing attacks.

2) Issue 2: Post-Simulation Feedback and Learning: The evidence on post-simulation feedback is mixed. Bender et al. found that just-in-time feedback reduced susceptibility to a second simulated phishing email sent two weeks later. Among employees who initially ignored the first email, feedback also increased later reporting [4]. The study does not report engagement with the feedback. This leaves open a possible explanation that cannot be directly compared with Ho et al. [4]. Ho et al. found very small differences between employees receiving embedded phishing training and those who did not. A substantial proportion of training sessions ended very quickly [3]. Low engagement may have limited the effect [3]. Gordon et al. found no substantial additional improvement after mandatory training for repeat clickers. The study cannot establish whether the training caused this result because there was no control group of repeat clickers who did not receive it [2]. Thus, Ho provides evidence of limited effects. Gordon is consistent with this but inconclusive. Bender provides a positive result.

For XY, Bender's workplace setting and Ho's healthcare setting provide workplace evidence, but neither directly matches XY's unionised energy workforce [3], [4]. This difference may affect trust and engagement with employer-provided feedback. Chen et al.'s qualitative study suggests that perceived value and privacy concerns can influence participation, although it does not measure intervention effectiveness [5].

3) Issue 3: Personalised Versus Standardised Training: **What does the evidence show?**

Schöni et al. investigated whether phishing training can be matched to users' existing proficiency and learning needs. The 2025 study compared personalised training with a random assignment approach. Overall proficiency, detection ability and security attitudes improved after training. Effects were most pronounced in the personalised condition, and the approach reduced disparities between initial proficiency groups. However, many direct comparisons lacked statistical significance. An exploratory analysis suggested that the match between training and proficiency was an important factor [6]. The 2026 work also examined proficiency-based grouping and reported improvements in proficiency and classification accuracy. The designs do not fully establish that personalisation is superior to a well-designed standardised programme in a workplace setting [7]. Both studies mainly measure performance on phishing classification tasks rather than long-term changes in real workplace behaviour.

How consistent is it?

The studies suggest that matching training to learner ability may be promising, but they do not by themselves establish that personalised training is always better than a common training programme. Both Schöni studies also come from the same research group and use online participants, which limits the strength of independent replication. Beu et al. examined actual behaviour in a naturalistic organisational simulation and found that risky behaviour was associated with several individual and contextual factors rather than detection ability alone [8]. The studies therefore address related but different questions rather than directly contradicting one another.

How applicable is it to XY?

Personalisation is potentially relevant because XY has technical and non-technical employees with different levels of experience. However, online classification performance may not predict how employees respond to unexpected phishing messages during normal work. The applicability of proficiency-based training to XY therefore requires validation using workplace behaviour rather than classification performance alone.

4) Issue 4: Individual Results, Privacy and Trust: **What does the evidence show?**

Chen et al. found that privacy concerns, worries about consequences, and poor communication could discourage employees from engaging with phishing interventions, based on focus groups with employees at a European university [5]. Reeves et al. similarly examined perceptions of organisational motives in security training, although this concerned security training generally rather than the handling of phishing results [9]. Beu et al. found that lower phishing detection accuracy only modestly predicted riskier behaviour, while employment length and satisfaction were stronger predictors [8]. Grill et al. examined information-security learning and managerial security leadership, but did not directly compare different approaches to reporting individual phishing results [10]. Rizzoni et al. reported that running simulations generated internal organisational concerns, including intervention by labour unions who requested that further emails be blocked. Misleading messages can produce backlash from staff and unions [11].

How consistent is it?

The findings do not directly conflict because the studies examine different outcomes, including employee perceptions, behavioural associations and security culture. Importantly, none of the reviewed studies directly compares aggregate-only reporting with disclosure of individual simulation results or with formal accountability measures. The reporting choice for XY is therefore a design inference rather than an evidence-established conclusion.

How applicable is it to XY?

The available evidence provides useful information about privacy, trust and employee perceptions, but much of it comes from university, healthcare or other organisational contexts rather than a unionised energy workforce. Rizzoni et al. is the only source that reports union involvement, and it concerns a single Italian hospital. Consequently, the effect of reporting individual results at XY cannot be predicted confidently from these studies alone. Union consultation, transparent data-use rules and clear limits on the use of simulation data are therefore issues that require local validation.

II. Part 2: Evidence-Based Design

TABLE II
EVIDENCE-BASED DESIGN DECISIONS

Design issue	Options considered	What does the evidence suggest?	What should XY do?	Why is this appropriate for XY?
Frequency and timing	More frequent campaigns (for example monthly). Approximately quarterly campaigns of moderate and varied difficulty. Infrequent (annual or ad-hoc) campaigns.	Gordon et al. associate higher numbers of campaigns with lower subsequent click odds, but the studies are observational and campaign difficulty was not controlled. No study identifies an optimal frequency. Ho et al. and Reeves et al. address engagement and advice fatigue rather than simulation schedule and should not be treated as direct evidence on cadence.	Conduct approximately four simulations per year, spaced at roughly quarterly intervals, using moderate and varied difficulty. (The specific cadence is a design judgement, not a figure tested in the literature.) Schedule campaigns to avoid known periods of high operational pressure where possible.	Provides repeated exposure consistent with the direction of the Gordon findings while remaining administratively manageable for a hybrid workforce of technical and non-technical staff. Leaves room for consultation with unions on timing.
Feedback and learning	Brief just-in-time feedback delivered immediately after interaction with a simulated email. Delayed formal remedial training for those who click. Structured feedback only for employees who fail repeatedly.	Bender et al. found that just-in-time feedback reduced susceptibility to a later simulated email and increased reporting among those who had ignored the first email. Ho et al. found only very small absolute differences from conventional embedded training and low engagement with training material. Gordon et al. found no substantial additional improvement from mandatory training for repeat clickers, although the absence of a control group limits causal inference.	Deliver brief, non-punitive just-in-time feedback immediately after an employee clicks or correctly reports a simulated phishing email. Avoid lengthy mandatory remedial modules as the default response.	Uses the moment when attention is highest, keeps time demand low, and reduces the risk that feedback will be perceived as punitive. This is an important consideration in a unionised setting.
Personalisation	Fully individualised content based on continuous assessment. Light proficiency-based differentiation of training content. Single standardised curriculum for all staff.	The Schöni studies indicate that proficiency-based personalisation can improve classification performance and reduce disparities between initial ability groups in online settings. Effects were most pronounced when training matched proficiency, although many direct comparisons lacked statistical significance. Both studies measure classification tasks rather than long-term workplace behaviour and come from the same research group. Beu et al. show that real-world risky behaviour is associated with factors beyond detection skill. A single prior click is therefore an incomplete basis for assignment.	Adopt light proficiency-based differentiation of training content where practical (for example, a short voluntary self-assessment or a brief composite measure), while retaining a common core curriculum. Full continuous individualisation is not recommended at this stage. Any use of prior simulation data should be treated as only one weak signal among others.	The choice stays close to the available experimental evidence on proficiency matching while remaining feasible for XY's hybrid technical and non-technical workforce. It avoids the cost and privacy overhead of continuous individual assessment and acknowledges the limitation identified by Beu et al.
Individual results	Individual results visible to line managers and available for formal accountability. Aggregate statistics only, with optional confidential personal feedback available to the employee on request. Aggregate statistics only, with no individual feedback.	No reviewed study directly compares aggregate-only reporting with individual disclosure or with formal accountability. Chen et al. and Reeves et al. document privacy concerns, fear of consequences and the importance of perceived organisational motives. Beu et al. show that individual click behaviour is only a partial indicator of security-related factors. Rizzoni et al. reported that simulations can generate organisational friction, including intervention by labour unions.	Report only anonymised aggregate statistics to management. Allow employees to request a confidential summary of their own results. Identifiable data should be held only by the security team responsible for delivering feedback, retained for a limited period (a design judgement of six months is suggested), and then anonymised or deleted. Data-use rules should be written jointly with unions and communicated clearly in advance. Formal accountability based on simulation clicks is not recommended on the present evidence.	Protects privacy and trust in a unionised environment while still permitting organisational learning and voluntary individual review. Limits the risk that simulation data will be used for informal or formal accountability in the absence of stronger evidence that individual clicks are reliable indicators of overall security behaviour.

III. PART 3: CRITICAL REFLECTION

A. Decision on simulation frequency (approximately quarterly campaigns)

Confidence level: Moderate

Reasoning: The association between higher numbers of campaigns and lower subsequent click rates is the most consistent finding available, appearing in both Gordon et al. studies. That consistency supports a schedule that includes repeated simulations rather than a single annual exercise. At the same time, the studies are observational, campaign difficulty was not held constant, and the research settings were US healthcare organisations rather than a unionised energy workforce. No study tested a specific quarterly cadence. The recommendation of approximately four campaigns per year is therefore a practical design judgement that follows the direction of the available evidence while remaining feasible for XY. Confidence is set at Moderate rather than Low because the directional evidence is consistent across the two analyses and

the alternative of very infrequent campaigns would ignore that pattern. It is not High because the evidence remains indirect and the precise cadence is untested. Note that both Gordon papers share authors, so the analyses are not fully independent.

Key uncertainty: Whether reductions in simulated click rates observed in other sectors will translate into improved detection of, and appropriate responses to, genuine phishing attempts under the operational conditions present at XY.

Effect on the recommendation: Evidence that would address this uncertainty includes systematic recording of real phishing incidents or near-misses reported by staff, together with any correlation between participation in the simulation programme and subsequent real-world outcomes. If such data showed little or no improvement in real detection or reporting, the frequency should be reduced and greater effort directed toward the quality, relevance and realism of each campaign. Conversely, clear gains in real-world reporting would support maintaining or carefully increasing the cadence.

B. Decision on individual results reporting (aggregate-only with optional confidential feedback)

Confidence level: Moderate

Reasoning: No study in the reviewed set directly compares aggregate-only reporting with disclosure of individual results to managers or with formal accountability measures. The recommendation is therefore an inference guided by related evidence on privacy, trust and the limited diagnostic value of single click events. Chen et al. and Reeves et al. show that privacy concerns and perceptions of organisational motives can reduce engagement. Beu et al. indicate that lower detection accuracy only modestly predicted riskier behaviour, while tenure and satisfaction were stronger predictors. Rizzoni et al. reported organisational friction, including union intervention, around simulation programmes in a single Italian hospital. This is the only union-related source in the set. These considerations are particularly relevant in a unionised setting. Confidence is set at Moderate rather than Low because the convergent qualitative and correlational evidence consistently points toward privacy and trust risks, and because the alternative of individual disclosure or formal accountability lacks supporting evidence of net benefit. It is not High because the comparison itself has never been tested and the transferability of the available studies to XY remains limited.

Key uncertainty: How XY's unionised workforce would react to the collection and retention of identifiable simulation data at all, even if managers never see individual names.

Effect on the recommendation: If consultation or a limited pilot showed that staff and unions regarded any identifiable collection as unacceptable, the programme should move to fully anonymised aggregate statistics with no individual feedback option. If staff accepted confidential personal feedback under clear, jointly agreed rules and no leakage to managers occurred, the current recommendation could be retained. Strong negative reaction would also argue against any later move toward formal accountability based on simulation results.

REFERENCES

[1] W. J. Gordon, A. Wright, R. Aiyagari, L. Corbo, R. J. Glynn, J. Kadakia, J. Kufahl, C. Mazzone, J. Noga, M. Parkulo, B. Sanford, P. Scheib, and A. B. Landman, "Assessment of employee susceptibility to phishing attacks at US health care institutions," *JAMA Network Open*, vol. 2, no. 3, p. e190393, 2019.

[2] W. J. Gordon, A. Wright, R. J. Glynn, J. Kadakia, C. Mazzone, E. Leinbach, and A. Landman, "Evaluation of a mandatory phishing training program for high-risk employees at a US healthcare system," *Journal of the American Medical Informatics Association*, vol. 26, no. 6, pp. 547–552, 2019.

[3] G. Ho, A. Mirian, E. Luo, K. Tong, E. Lee, L. Liu, C. A. Longhurst, C. Dameff, S. Savage, and G. M. Voelker, "Understanding the efficacy of phishing training in practice," in *2025 IEEE Symposium on Security and Privacy*, 2025, pp. 37–54.

[4] S. Bender, S. Horn, G. Loewenstein, and O. Roberts, "Phishing feedback: just-in-time intervention improves online security," *Behavioural Public Policy*, vol. 10, no. 3, pp. 527–539, 2026.

[5] X. Chen, S. Doublet, A. Sergeeva, G. Lenzini, V. Koenig, and V. Distler, "What motivates and discourages employees in phishing interventions: An exploration of expectancy-value theory," in *Proceedings of the Twentieth Symposium on Usable Privacy and Security (SOUPS 2024)*. USENIX Association, 2024, pp. 487–506. [Online]. Available: https://www.usenix.org/conference/soups2024/presentation/chen

[6] L. Schöni, N. Roch, H. Sievers, M. Strohmeier, P. Mayer, and V. Zimmermann, "It's a match - enhancing the fit between users and phishing training through personalisation," in *Proceedings of the 2025 CHI Conference on Human Factors in Computing Systems*. Association for Computing Machinery, 2025, pp. 1–25, article 592.

[7] L. Schöni, N. Roch, V. Carles, H. Sievers, M. Strohmeier, P. Mayer, and V. Zimmermann, "Phishing for proficiency: evaluating proficiency-based categorisation for personalised phishing training," *Information and Computer Security*, 2026, advance online publication.

[8] N. Beu, A. Jayatilaka, M. Zahedi, M. A. Babar, L. Hartley, W. Lewinsmith, and I. Baetu, "Falling for phishing attempts: An investigation of individual differences that are associated with behavior in a naturalistic phishing simulation," *Computers & Security*, vol. 131, p. 103313, 2023.

[9] A. Reeves, D. Calic, and P. Delfabbro, ""Generic and unusable": Understanding employee perceptions of cybersecurity training and measuring advice fatigue," *Computers & Security*, vol. 128, p. 103137, 2023.

[10] M. Grill, T. Sommestad, H. Karlzén, and A. Pousette, "Training for improved information security culture: a longitudinal randomized controlled trial," *Information and Computer Security*, vol. 33, no. 5, pp. 690–718, 2025.

[11] F. Rizzoni, S. Magalini, A. Casaroli, P. Mari, M. Dixon, and L. Coventry, "Phishing simulation exercise in a large hospital: A case study," *Digital Health*, vol. 8, pp. 1–13, 2022.